

PeerLink KACST Quarterly VA Findings Register — 2026 Q3

Assessment ID: PeerLink-2026-Q3-VA

Assessment date: 11 August 2026

Production target: p2p.iiothsolutions.sa and its OCI host/control plane

Branch assessed/remediated: feature/kacst-quarterly-vulnerability-assessment

Status definitions

- **Closed — verified locally:** code/config remediation passed local retest but is not yet production evidence.
- **Open — production action:** a host, credential, or deployment action needs an approved maintenance window.
- **Open — dependency/vendor:** no supported fix is currently installable without an upstream compatibility change.
- **Accepted/monitored:** exposure is intentional and protected by compensating controls.
- **Informational/pass:** control was tested and no vulnerability was found.

Findings

ID	Severity	Confidence	Finding	Evidence	Remediation / disposition	Retest	Status
Q3 - VA -001	Critical aggregate scanner rating	Low until mapped	OCI VSS returned 1,000 records: 193 Critical, 649 High and 158 Medium. Only three records identify vulnerable packages; 997 have no package mapping.	OCI host scan completed 2026-08-11T01:13:39Z .	Do not present all 1,000 as confirmed vulnerabilities. Validate package presence/applicability. The three mapped High records concern host python3-pip / python3-wheel and ESM fix versions. Patch or remove them in an approved window.	Fresh scan required after host maintenance.	Open — production action
Q3 - VA -002	High	High	Backend dependency baseline contained 34 advisory records across nine packages.	pip-audit before/after records.	Updated FastAPI/Pydantic/SuperTokens/Motor/PyMongo/multipart/mail/AWS dependencies and removed unused python-jose .	Deployed tree reduced 34 to one advisory. Running image versions were inspected directly; 32 deployed-image tests and acceptance passed.	Closed in production; one residual tracked in Q3-VA-003
Q3 - VA -003	High	High	cryptography 49.0.0 has PYSEC-2026-3552 ; fixed in 50.0.0. Current fastapi-mail 1.6.5 requires <50 .	Final pip-audit and Trivy backend image scan.	Keep the finding visible; do not force an unsupported resolver override. Track a compatible FastAPI-Mail release or replace the mail abstraction, then upgrade and retest OTP/invitation/password-reset mail.	Final audit still reports exactly one known backend dependency finding.	Open — dependency/vendor

ID	Severity	Confidence	Finding	Evidence	Remediation / disposition	Retest	Status
Q3 - VA -0 04	High	High	Frontend production dependency audit initially returned four vulnerabilities.	npm audit before/after.	Applied supported lockfile remediation.	Current production-branch full/production-only npm audit : 0; deployed frontend Trivy: 0; production build passed.	Closed — verified in production
Q3 - VA -0 05	High	Medium	Production Compose stored default database credentials and a placeholder application secret in tracked configuration. A tracked value must be treated as exposed even if access is network-restricted.	Compose review and tracked-source scan.	Replaced values with mandatory deployment variables, added a non-secret production template, and retained loopback-only database bindings. Existing values were moved to the untracked production environment during deployment without disclosure.	Production Compose has no tracked defaults and database bindings are loopback-only. Actual credential rotation remains pending.	Deployment closed; credential rotation open
Q3 - VA -0 06	Medium	High	Production OpenAPI schema was publicly accessible at /api/v1/openapi.json (HTTP 200).	Original public GET on 11 August 2026.	Disabled Swagger, ReDoc and OpenAPI when ENVIRONMENT=production; retained them in non-production environments.	Direct post-deployment public retest on 12 August returned HTTP 404.	Closed — verified in production
Q3 - VA -0 07	Medium	High	Production backend Compose used a source bind mount and Uvicorn --reload, increasing mutable-code and development-runtime exposure.	Compose review.	Removed the bind mount and reload mode; production image now runs copied code with four non-root workers.	Direct container inspection confirmed appuser, no backend mounts, four Uvicorn workers, healthy state and zero restarts.	Closed — verified in production
Q3 - VA -0 08	Medium	High	Latest OCI CIS check 5.2.14 reports that only strong SSH MAC algorithms are not enforced.	OCI managed scan completed before the final release: 17 pass, 1 fail.	Direct sshd -T now shows key-only authentication and only hmac-sha2-512-etm, hmac-sha2-256-etm, and umac-128-etm; configuration syntax and a second direct SSH session passed.	Trigger/review a fresh OCI CIS scan to reconcile the managed score before closure.	Open — managed rescan/reconciliation
Q3 - VA -0 09	Medium	High	The inner frontend NGINX response lacked several browser defense headers; the first deployment also exposed an NGINX add_header inheritance gap on the app shell.	Public/inner header captures and active NGINX configuration.	Added and deployed nosniff, SAMEORIGIN, strict-origin referrer policy and restrictive permissions policy, explicitly repeating them in the index.html location.	Commit bdb03b5, workflow 31539611417; inner and public app-shell responses now contain all four headers plus public HSTS/CSP.	Closed — verified in production
Q3 - VA -0 10	Medium	High	SuperTokens Python SDK remediation requires CDI 5.4; core 11.0 supports only through CDI 5.3.	Reproduced signup failure after SDK update.	Pinned and deployed SuperTokens core 11.3.7, which supports CDI 5.4. Avoided 12.0 because direct 11.0-to-12.0 local upgrade did not migrate one schema column correctly.	Production backups passed; core 11.3.7 is running and the deployed failed-login acceptance passed.	Closed — verified in production
Q3 - VA -0 11	Medium scanner / Low confidence	Low	Bandit B608 matched string interpolation in OCI Object Storage URL construction as possible SQL injection.	app/services/s3_service.py, URL-generation function.	Reviewed manually: the code constructs an HTTPS object URL and executes no SQL.	No SQL API or database call exists in the matched function.	Closed — false positive

ID	Severity	Confidence	Finding	Evidence	Remediation / disposition	Retest	Status
Q3 - VA-012	Low	High	Bandit reported ten swallowed-exception patterns (B110/B112).	Final Bandit scan.	Retain as code-quality backlog; no direct exploit path was established. Add structured logging when these paths are next modified.	No High-severity Bandit findings.	Open — engineering backlog
Q3 - VA-013	Critical/High scanner records	Medium	Deployed backend image has 4 Critical and 20 High records. Four Critical and 19 High OS records have no vendor fixed version; the only fixable High is Q3-VA-003.	Fresh Trivy scan of actual production <code>docker-backend:latest</code> on 12 August: 4 Critical, 20 High, 56 Medium, 66 Low, 33 Unknown.	Supported Debian 13/Python base, available OS upgrades and reduced build/runtime tooling are deployed. Re-scan when Debian or dependency fixes publish; evaluate distroless only through a separately tested architecture change.	Production scan reproduced the expected result: no fixable Critical and one constrained fixable High.	Open — vendor monitoring; production verified
Q3 - VA-014	Informational/pass	High	Frontend runtime image has no detected vulnerabilities.	Fresh Trivy scan of actual deployed <code>docker-frontend:latest</code> on 12 August.	Updated Node build stage, NGINX runtime and Alpine packages.	0 Critical, High, Medium or Low records; current production-branch <code>npm audit</code> also returns 0.	Informational/pass — production verified
Q3 - VA-015	Medium accepted exposure	High	Public TCP 22 remains reachable.	Independent external connection check.	SSH is key-only, Fail2ban is enabled, and OCI Bastion is staged. Keep public SSH only until a tested Bastion cutover is approved.	TCP 22, 80, 443 reachable; 3567, 5173, 5432, 8000, 8520 and 27017 filtered/unreachable.	Accepted/monitored; cutover pending
Q3 - VA-016	Informational/pass	High	TLS, redirect, CORS and unsafe method baseline is strong.	Public curl/OpenSSL checks.	No change required in this branch.	HTTP redirects to HTTPS; HTTP/2 200; TLS 1.0/1.1 rejected; TLS 1.2/1.3 accepted; untrusted CORS rejected; TRACE/PUT/DELETE return 405.	Informational/pass
Q3 - VA-017	Informational/pass	High	No secret was detected in tracked source at assessment or post-release retest time.	Gitleaks 8.30.1 against an archive of deployed commit <code>bdb03b5</code> .	Continue secret scanning and rotate any credential ever committed regardless of scanner result.	Fresh post-release tracked-source scan: 0 findings.	Informational/pass — production commit verified
Q3 - VA-018	High operational	High	The OCI host currently has 23 upgradable packages, including Docker/containerd, NGINX, AppArmor and cloud-init components.	Direct <code>apt-get -s upgrade</code> on 12 August 2026.	Assess release notes, create/reconfirm backups, apply in an approved host-maintenance window and complete service/reboot/retest decisions.	Pending maintenance.	Open — production action
Q3 - VA-019	Repository/default-branch alerts	High	GitHub reports 24 open npm Dependabot alerts on the default-branch lockfile: 1 Critical, 12 High, 10 Medium, 1 Low. This differs from the assessed production branch.	GitHub Dependabot API and current production-branch <code>npm audit</code> .	Synchronize/triage the default branch. Do not misstate these alerts as deployed-image findings: production-branch <code>npm audit</code> and deployed frontend Trivy both return zero.	Pending default-branch synchronization/closure.	Open — repository governance

Production action queue

1. Generate/rotate production PostgreSQL, MongoDB and application secrets through the approved secret-handling process.

2. Assess/apply the 23 pending host upgrades and patch/remove mapped `python3-pip / python3-wheel` packages in an approved window.
3. Run fresh OCI VSS/CIS after host maintenance and reconcile CIS 5.2.14 against effective SSH configuration.
4. Disable unnecessary RPC port 111 listeners as defense in depth; external reachability is already blocked.
5. Synchronize and triage the default branch's 24 Dependabot alerts.
6. Monitor Q3-VA-003 and Q3-VA-013 for vendor fixes.
7. Complete optional literal-duration role evidence only if requested and obtain internal sign-off.

Application deployment, backups, OpenAPI suppression, immutable application runtime, SuperTokens 11.3.7, browser headers and production acceptance are complete. The queue above remains explicitly open and must not be represented as remediated.